



NYU Software Supply Chain Security Operations Center (NSOC)

13 Jun 2026

Modern software is largely built on open-source foundations: 98% of analyzed code-bases contain open source components, with the average application now depending on a mean of over 1,180 of such components, a 30% increase in just one year [2]. This dependency landscape is scattered across dozens of ecosystems, each with its own distinct but interdependent communities, governance models, and tooling. There is simply not enough expertise, tooling, or comprehensive guidance across the ecosystems because the required scale of expert effort does not yet exist.

The NYU Software Supply Chain Security Operations Center (NSOC) is dedicated to building the capability to surface and address threats across the open-source ecosystems that feed modern software. Powered by the intelligence of [ecosyste.ms](#), covering 14 million packages, 287 million repositories, and 24.5 billion dependencies, NSOC continuously monitors environments like Python, Rust, Ruby, Java, and GitHub, catching threats before they reach production systems. From a workforce standpoint, we use a rigorous, multi-year training program. This will also involve training from world-class experts on using AI models to find vulnerabilities in open source software. Each graduate student will be guided to become a meaningful contributor to an open source ecosystem. NSOC is positioned to monitor the open-source ecosystems that underpin modern software delivery, while actively working to improve the security posture of the organizations and foundations that depend on them, through ecosystem report cards, per-ecosystem guidance, and direct code integrations.

Motivation

The integrity of modern software depends on the integrity of its dependencies. High-profile incidents, from the SolarWinds [4] compromise to the XZ Utils backdoor [1], have demonstrated that adversaries who corrupt software can reach production systems undetected, including open-source ecosystems that underpin modern software delivery. Yet the problem runs deeper than individual attacks: modern software projects depend on thousands of open source packages across multiple ecosystems, each maintained by different contributors under different governance models, creating an enormous and constantly shifting attack surface. Meanwhile, the window to respond is shrinking, mean time to compromise has dropped from three days to negative seven days, meaning attackers now exploit vulnerabilities before patches are even released [6]. Once inside, adversaries move fast: the average breakout time has fallen to just 29 minutes, with the

fastest observed at 27 seconds [3]. At the same time, new attacks like the openpcp attack exploits GitHub's own CI/CD infrastructure to distribute malware that spreads across package language types, showing that ecosystems cannot be secured in isolation [5]. This creates an enormous, constantly shifting attack surface that no single organization can monitor on its own. By the time a vulnerability is publicly disclosed, organizations are already exposed.

Description

NSOC develops software supply chain experts which apply the open-source intelligence of ecosyste.ms to continuously monitor the ecosystems that feed enrolled projects, surfacing possible threats. NSOC tracks dependency changes, new attack vectors, and anomalous package behavior across ecosystems to alert organizations before exposure becomes an incident.

Hosted at NYU's Tandon School of Engineering in the Center for Cyber Security, NSOC brings together master's students, PhD researchers, and postdoctoral associates under the supervision of Prof. Justin Cappos (sometimes called the "father of software supply chain security"), Prof. Jiahao Yu (whose team won \$3M in the DARPA AIXCC challenge), and Andrew Nesbitt (founder of ecosyste.ms). We will create software supply chain security experts through real-world experience. In particular, the center has four main goals:

Connect

NSOC will train a cadre of master's students, each serving as a dedicated liaison between NSOC and a specific open-source ecosystem. These students do more than observe; they become active, trusted participants in their assigned communities. For example, a NSOC liaison could help the Python Software Foundation work through their backlog of package ownership change requests (PEP 541) [7]. Before engaging as security liaisons, each student undergoes structured onboarding that emphasizes the norms, culture, and contribution expectations of their ecosystem. This groundwork builds credibility and earns the trust that makes security conversations possible. The result is a human infrastructure that complements automated monitoring: relationships and institutional knowledge that no pipeline can replicate, and a growing network of security-aware contributors embedded across the ecosystems that modern software depends on.

Inspect

AI-driven vulnerability detection and repair has rapidly advanced, with Mythos demonstrating that LLM-based agents can identify vulnerabilities, generate patches, and assist human analysts at unprecedented scale. Under the guidance of top tier experts in LLM guided vulnerability discovery, students will scan important open source frameworks to develop and refine cutting edge techniques for how to use LLMs for security analysis. With guidance from groups like Alpha-Omega and the OpenSSF, we will model our

disclosure and outreach on Google's Project Zero and Project Glasswing. Students and our domain experts will disseminate guidance about what does and does not work effectively in this manner across the security community, while also targeting and responsibly disclosing bugs in high impact projects.

Detect

NSOC will continuously monitor signals across open-source ecosystems to surface security vulnerabilities. This monitoring is powered primarily by `ecosyste.ms`, which serves as the intelligence backbone for tracking dependency changes and anomalous package behavior at scale, complemented by rolling security scans across critical projects. NSOC analysts examine signals across ecosystems simultaneously, identifying suspicious dependency injections, and unmaintained-but-apparently-alive ("Bernie") critical components that represent latent risk. Some example projects include monitoring trusted publishing adoption across ecosystems and evaluating differences in security and usability between implementations; an analysis of `post_install` scripts including how many packages have them, what they are used for, their history, what percentage are dangerous, along with suggestions to ecosystems about how they might sandbox, phase out, or restrict the use of this overpermissioned mechanism. This will help open source software stay ahead of emerging threats.

Direct

NSOC will produce annual guidance on the state of package security, translating monitored signals and research findings into actionable recommendations for the broader ecosystem community. NSOC will publish per-ecosystem report cards that assess security posture across dimensions such as trusted publishing adoption, dependency hygiene, and responsiveness to disclosed vulnerabilities, giving ecosystem maintainers and downstream consumers a picture of where risks concentrate. Beyond reporting, NSOC liaisons will deliver technical assistance through code integrations, helping package managers implement concrete security improvements rather than simply identifying gaps. These efforts will be coordinated with established standards bodies and working groups, including OpenSSF WGs, NIST, and relevant ecosystem governance organizations, to ensure that NSOC's recommendations align with and strengthen existing frameworks, while also informing industry-wide policy.

Expected Impact

NSOC provides a center for cross-ecosystem problem solving and information sharing. We will use NSOC to deliver early warning on upstream threats before they surface in formal advisories. This operational impact extends outward: NSOC's annual ecosystem report cards, ecosystem-specific security guidance, and direct code integrations will measurably improve the security posture of the package managers on which the broader

industry depends. All tooling, datasets, and findings will be released publicly, providing the broader tech community with data and tooling that is not available today.

Additional Information

NSOC is headed by world class experts. Prof. Cappos has extensive real-world experience building widely adopted software supply chain security technologies, including TUF, Uptane, gittuf, in-toto, Git's security architecture, millions of vehicles, etc. Prof. Yu is a cyber-AI expert whose work on AI-driven vulnerability discovery, fuzzing, and automated patch generation won a \$3M USD prize in the DARPA AI Cyber Challenge (AIXCC). Andrew Nesbitt (creator of [ecosyste.ms](#)) is one of the foremost security researchers performing data analysis at scale and is part of Glasswing. Our team of experts will replicate and infuse our skills into a pipeline of the next generation of software supply chain security experts.

Bibliography

- [1] Akamai Security Intelligence Group. 2024. XZ Utils Backdoor. Retrieved June 13, 2026 from <https://www.akamai.com/blog/security-research/critical-linux-backdoor-xz-utils-discovered-what-to-know>
- [2] Black Duck. 2026. 2026 Open Source Security and Risk Analysis Report. Retrieved from <https://www.blackduck.com/resources/analyst-reports/open-source-security-risk-analysis.html>
- [3] Crowdstrike. 2026. 2026 Global Threat Report. Retrieved June 13, 2026 from <https://www.crowdstrike.com/en-us/global-threat-report/>
- [4] Fortinet. 2026. SolarWinds Supply Chain Attack. Retrieved June 13, 2026 from <https://www.fortinet.com/resources/cyberglossary/solarwinds-cyber-attack>
- [5] Jeremy Kirk and George Wang. 2026. Defending against TeamPCP software supply chain attacks. Retrieved June 13, 2026 from https://www.okta.com/en-gb/blog/threat-intelligence/defending_against_team_pcp_software_supply_chain_attacks/
- [6] Jurgen Kutscher. 2026. M-Trends 2026: Data, Insights, and Strategies From the Frontlines. Retrieved June 13, 2026 from <https://cloud.google.com/blog/topics/threat-intelligence/m-trends-2026>
- [7] Python Software Foundation. 2018. PEP 541 – Package Index Name Retention. Retrieved June 13, 2026 from <https://peps.python.org/pep-0541/>